

System Architecture & Control Framework

Document ID: DOC-ARCH-004
Classification: Official
System: Case Ace v2.0 (Citizens Advice Wandsworth)
Standard Alignment: ISO/IEC 27001:2022, ISO/IEC 27701:2019, ISO/IEC 27018:2019, ISO/IEC 42001:2023, Advice Quality Standard (AQS) Level 3

1. Repository & Directory Structure

case-ace-v2/	
% % % client/	# Pure client-side React 19 SPA (Vite + TypeScript)
% % % % src/	
% % % % % config/	# Environment & security config (local, test, pilot)
% % % % % state/	# VolatileSessionStore (RAM only, C1/C3)
% % % % % components/	# Accessible UI components (WCAG AAA / AQS L3)
% % % % % styles/	# Self-hosted system styling (zero external CDNs)
% % % % % App.tsx	# Main application workflow container
% % % % % main.tsx	# Entry point
% % % % index.html	# Hardened HTML template with CSP
% % % % vite.config.ts	# Build & dev server security headers
% % % % package.json	# Pinned client dependencies
% % % backend/	# Minimal stateless Node.js service (Express + TypeScript)
% % % % src/	
% % % % % config/	# Backend environment & region settings (europe-west2)
% % % % % middleware/	# Strict CSP & security headers
% % % % % routes/	# Health, Auth (2FA), Scoped Tokens, Telemetry (No PII)
% % % % % server.ts	# Server bootstrap
% % % % package.json	# Pinned backend dependencies
% % % infrastructure/	# Deployment & containerization manifests
% % % % docker/	# Hardened Dockerfiles (client Nginx, backend Node)
% % % % env/	# Environment variable examples (.env.local, .test, .pilot)
% % % % gcp/	# Cloud Run service definitions (pinned to europe-west2)
% % % docs/	# Architectural, dependency, and compliance specifications
% % % % architecture.md	# This document
% % % % dependencies.md	# Supply chain & dependency justification register
% % % % csp.md	# Content Security Policy specification
% % % % environments.md	# Environment isolation and data policy
% % % test/	# Unit, integration, CSP, and dependency test suites
% % % % csp.test.ts	# Automated CSP header and directive verification
% % % % dependencies.test.ts	# Automated dependency pinning and network audit test
% % % % environments.test.ts	# Automated environment config validation test
% % % % synthetic-fixtures/	# Synthetic consultation test fixtures
% % % evidence/	# Automated control evidence artefacts (ISO 27001/42001)
% % % % sbom.json	# Software Bill of Materials (CycloneDX format)
% % % % dependency-audit.json	# Static network & telemetry audit of packages
% % % % csp-evaluation.json	# Automated CSP evaluation record

2. Information Security & AI Governance Control Mapping

ISO/IEC 27001:2022 / 27002:2022:

A.8.20 (Network security) \$→\$ Strict CSP, zero unapproved network calls.

A.8.24 (Use of cryptography) \$→\$ TLS 1.3 in transit, PKCE OAuth 2.0.

A.8.26 (Application security requirements) \$→\$ Zero non-volatile client/server storage.

A.8.30 (Outsourced development & supply chain) \$→\$ Pinned dependencies, SBOM generation.

A.8.31 (Environment separation) \$→\$ Local, Test, Pilot isolated; synthetic fixtures.

ISO/IEC 27701:2019 / 27018:2019:

Data minimization and purpose limitation (UK GDPR Art 5).

Region pinning to europe-west2 (UK data sovereignty).

Video track immediate disposal on decode (C10).

ISO/IEC 42001:2023 (Artificial Intelligence Management):

Human-in-the-loop gating at all trust boundaries (C6).

Redaction verification before external cloud invocation (C4, C8).

Local synthetic tokenisation before LLM drafting (C5).